

W12D4 - Emy Mangogna

Report scansione vulnerabilità

Table of contents

Executive Summary.....	p2
Prima Scan di Nessus.....	p2
Findings.....	p3
• Description.....	p4
• Protocollo e causa tecnica.....	p4
• Impatto/rischio.....	p4
• Come viene sfruttata.....	p4
• Evidenza fonita da Nessus.....	p5
• Indicatori di compromissione / cosa controllare.....	p5
• Rilevamento e prevenzione	p5
• Contromisure e mitigazioni	p5
Verifica dopo mitigazione.....	p6
Note sul contesto del plugin.....	p6
Walkthrough remediation.....	p7
• Comandi su Kali (attaccante)	p7
• Comandi su Meta (target)	p8
• Verifica su Kali (attaccante).....	p13
Seconda scan di Nessus.....	p13
Conclusion.....	p13

Executive Summary

Questo report riassume i risultati di una scansione **Nessus** condotta su una macchina virtuale e documenta l'analisi di una vulnerabilità critica riscontrata. Vengono fornite la causa, valutazione dell'impatto e della probabilità di sfruttamento e raccomandazioni tecniche di remediation.

Dopo l'applicazione delle remediation è stata eseguita un'altra scansione con Nessus di follow-up e controlli mirati con nmap per confermare la rimozione dei servizi/protocolli/cipher esposti e la chiusura delle porte interessate.

Target: Metasploitable (192.168.50.101)

Tools: Nessus, Nmap

First Scan Details

Policy: Basic Network Scan

Status: completed

Severity Base: CVSS v3.0

Start: September 28 at 5:58 PM

End: September 28 at 6:28 PM

Elapsed: 30 minutes

192.168.50.101					
6	1	20	7	72	
CRITICAL	HIGH	MEDIUM	LOW	INFO	
Vulnerabilities					Total: 106
SEVERITY	CVSS V3.0	VPR SCORE	EPSS SCORE	PLUGIN	NAME
CRITICAL	9.8	-	-	51988	Bind Shell Backdoor Detection
CRITICAL	9.8	-	-	20007	SSL Version 2 and 3 Protocol Detection
CRITICAL	10.0	-	-	201352	Canonical Ubuntu Linux SEoL (8.04.x)
CRITICAL	10.0*	-	-	32314	Debian OpenSSH/OpenSSL Package Random Number Genera Weakness
CRITICAL	10.0*	-	-	32321	Debian OpenSSH/OpenSSL Package Random Number Genera Weakness (SSL check)
CRITICAL	10.0*	-	-	61708	VNC Server 'password' Password

Findings

VNC Server 'password' Password

61708 - VNC Server 'password' Password

Synopsis

A VNC server running on the remote host is secured with a weak password.

Description

The VNC server running on the remote host is secured with a weak password. Nessus was able to login using VNC authentication and a password of 'password'. A remote, unauthenticated attacker could exploit this to take control of the system.

Solution

Secure the VNC service with a strong password.

Risk Factor

Critical

CVSS v2.0 Base Score

10.0 (CVSS2#AV:N/AC:L/Au:N/C:C/I:C/A:C)

Plugin Information

Published: 2012/08/29, Modified: 2015/09/24

Plugin Output

tcp/5900/vnc

Nessus logged in using a password of "password".

Plugin Details

Severity: Critical

ID: 61708

Version: \$Revision: 1.2 \$

Type: remote

Family: Gain a shell remotely

Published: August 29, 2012

Modified: September 24, 2015

Risk Information

Risk Factor: Critical

CVSS v2.0 Base Score: 10.0

CVSS v2.0 Vector:

CVSS2#AV:N/AC:L/Au:N/C:C/I:C/A:C

Description

Il server VNC sul host 192.168.50.101 accetta una password debole: Nessus è riuscito ad autenticarsi usando la password "**password**". Questo significa che un attaccante remoto non autenticato può ottenere accesso remoto alla sessione grafica e potenzialmente al sistema operativo.

Protocollo e causa tecnica

- VNC usa il protocollo **RFB (Remote Framebuffer)**. Molte implementazioni VNC usano una autenticazione "legacy" basata su una password locale.
- La versione classica della password VNC è spesso **limitata a 8 caratteri** e usa una forma di cifratura/compatibilità debole (DES in modalità molto semplice o meccanismi proprietari) senza salting né protezione moderna.
- Molti server VNC non cifrano i dati della sessione (mouse/tastiera/schermo) né la password, quindi l'autenticazione può essere intercettata su rete non affidabile.
- Se la password è banale (es. "password"), strumenti automatici o scansioni come Nessus possono autenticarsi subito.

Impatto/Rischio

- Accesso remoto completo alla sessione grafica dell'utente che esegue il server VNC.
- Possibile esecuzione di comandi, trasferimento file, innesto di malware, raccolta di credenziali visibili, pivoting laterale nella rete.
- Classificazione: **Critical** (Nessus riporta CVSS v2 10.0 per questo plugin specifico perché permette compromissione completa senza autenticazione).
- Se il VNC è eseguito con privilegi elevati (es. su una sessione di sistema o come servizio), l'impatto è massimo.

Come viene sfruttata

- **Accesso diretto**: connessione al port 5900/TCP (di default) e autenticazione con password debole.
- **Brute force / dizionario**: password corte/banali vengono trovate rapidamente.
- **Man-in-the-middle / sniffing**: su reti non cifrate, le credenziali o la sessione possono essere intercettate.
- **Automatizzati**: scanner (Nessus, masscan, script) che testano password comuni.

Evidenza fornita da Nessus

- “Nessus logged in using a password of "password"”
autenticazione confermata da scanner: la password è effettivamente valida.

Indicatori di compromissione / cosa controllare

- Connessioni TCP in entrata su 5900 (o porte alternative configurate per VNC).
- Processi VNC attivi (nome tipico: vncserver, Xvnc, vino-server, TigerVNC, RealVNC, TigerVNC, etc.).
- Log del server VNC che mostrano autenticazioni riuscite (se il server logga questi eventi).
- File di configurazione con password in chiaro (alcune implementazioni memorizzano hash o password).
- Eventi di sistema poco usuali dopo l’orario di accesso remoto: processi lanciati, account creati, connessioni esterne.
- PCAP: handshake RFB seguito da autenticazione riuscita (utile per confermare sessione remota).

Rilevamento e prevenzione

- Monitorare connessioni su 5900/TCP e pattern di scansione su porte RFB.
- IDS/IPS con regole per rilevare handshake RFB o tentativi di autenticazione anomali.
- Registrare e allertare su autenticazioni VNC fuori orario o da IP esterni.

Contromisure e mitigazioni

- **Immediato:** cambiare la password VNC con una forte (~almeno 12 caratteri, complessa) e rimuovere password banali.
- **Migliore pratica:** disabilitare accesso VNC diretto dall’esterno; permettere l’accesso solo tramite **VPN** o **tunnel SSH**.
- **Crittografia:** usare versioni di VNC che supportano TLS/SSL (es. veNCrypt, RealVNC con encryption) o forzare cifratura del canale.
- **Restrizioni di accesso:** limitare IP ammessi tramite firewall (ACL) e utilizzare connessioni solo da reti fidate.
- **Principio del minimo privilegio:** eseguire il server VNC con account a basso privilegio quando possibile.
- **Autenticazione più forte:** dove possibile integrare con autenticazione a due fattori o autenticazione di sistema (es. autenticazione tramite PAM).
- **Rimuovere/Disinstallare:** se VNC non è necessario, disabilitarlo o rimuoverlo completamente.
- **Hardening:** evitare memorizzazione di password in chiaro e abilitare logging/alerting.

Verifica dopo mitigazione

- Rieseguire la scansione Nessus: il plugin 61708 non dovrebbe più riportare “logged in using a password of 'password'”.
- Testare accesso via VPN/SSH e verificare che l’accesso diretto su 5900 sia bloccato dall’esterno.
- Controllare i log per tentativi di accesso falliti e far partire monitor/alerting.

Note sul contesto del plugin

- Il plugin segnala che la vulnerabilità è stata **sfruttata** dal tool di scansione (autenticazione riuscita). Questo non prova necessariamente che il server sia stato compromesso in passato, ma dimostra che è *possibile* comprometterlo con facilità.
- CVSS v2 10.0 indica impatto massimo secondo quella metrica; in pratica significa che la situazione va trattata con priorità massima.

Walkthrough remediation

Su Kali (192.168.50.100):

Verificare porta aperta

```
nmap -p 5900 192.168.50.101
```

Il comando scansiona la porta 5900/TCP del target per vedere se è aperta (porta VNC di default) per confermare che il servizio VNC è raggiungibile prima di procedere.

```
(nemi@kali)-[~]  
♥ nmap -p 5900 192.168.50.101  
Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-02 15:08 CEST  
Nmap scan report for 192.168.50.101  
Host is up (0.00053s latency).  
  
PORT      STATE SERVICE  
5900/tcp  open  vnc  
MAC Address: 08:00:27:09:7A:98 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)  
  
Nmap done: 1 IP address (1 host up) scanned in 13.35 seconds
```

Prova autenticazione (PoC)

```
vncviewer 192.168.50.101:5900
```

Il comando apre un client VNC che tenta di connettersi al server; chiederà la password VNC. (Nessus ha già mostrato che password funziona).

Quando richiesto inserire: **password**.

Il client si connette e mostra la sessione remota (o mostra "Authentication succeeded")

```
(nemi@kali)-[~]  
♥ vncviewer 192.168.50.101:5900  
Connected to RFB server, using protocol version 3.3  
Performing standard VNC authentication  
Password:  
Authentication successful
```

Su Meta (192.168.50.101):

Trova PID server VNC

```
pgrep -f 'Xtightvnc|Xvnc|Xtigervnc|tightvnc|vncserver|vncconnect|vino-server'
```

Il comando cerca nella riga di comando dei processi attivi parole chiave tipiche dei server VNC e restituisce i loro PID. Serve a identificare se e quale istanza VNC è in esecuzione (PID - 4729) in modo da poter poi ottenere la riga di comando completa o fermare l'istanza corretta.

```
msfadmin@metasploitable:~$ pgrep -f 'Xtightvnc|Xvnc|Xtigervnc|tightvnc|vncserver|vncconnect|vino-server'
4729
```

Mostra dettagli processo VNC

```
ps -p 4729 -o pid,user,cmd
```

Il comando mostra il PID, l'utente proprietario e la riga di comando completa del processo VNC identificato in precedenza (PID 4729). Serve a capire quale display VNC è in uso, quale utente lo esegue e con quale comando, informazioni necessarie per fermare o configurare correttamente il server.

```
msfadmin@metasploitable:~$ ps -p 4729 -o pid,user,cmd
  PID USER      CMD
  4729 root      Xtightvnc :0 -desktop X -auth /root/.Xauthority -geometry 1024x768
```

Termina processo come root

```
sudo kill 4729
```

Il comando invia SIGTERM al processo con PID 4729 usando i privilegi di root (password: msfadmin).

```
msfadmin@metasploitable:~$ sudo kill 4729
[sudo] password for msfadmin:
msfadmin@metasploitable:~$
```

Verifica che il processo sia terminato

```
ps -p 4729 -o pid,cmd
```

Il comando controlla se il PID 4729 è ancora in esecuzione.
L'output non mostra più 4729.

```
msfadmin@metasploitable:~$ ps -p 4729 -o pid,cmd
PID CMD
msfadmin@metasploitable:~$
```

Controllo porte VNC (root)

```
sudo ss -ltnp | egrep ':5900|:5901'
```

Il comando mostra le socket TCP in ascolto (-ltnp) e filtra quelle su porta 5900/5901.
L'output sarà (vuoto)

```
msfadmin@metasploitable:~$ sudo ss -ltnp | egrep ':5900|:5901'
msfadmin@metasploitable:~$ _
```

Verifica directory .vnc (root e msfadmin)

```
ls -l /root/.vnc /home/msfadmin/.vnc 2>/dev/null
```

Il comando elenca dettagli (permessi, proprietario, dimensione, data, nome) dei file presenti nelle directory **/root/.vnc** e **/home/msfadmin/.vnc**.

Serve a controllare se esistono file importanti di TightVNC (es. passwd, *:0.pid, xstartup) e a verificare i permessi;

la **parte 2>/dev/null** sopprime eventuali messaggi di errore se una delle directory non esiste.

```
msfadmin@metasploitable:~$ ls -l /root/.vnc /home/msfadmin/.vnc 2>/dev/null
/home/msfadmin/.vnc:
total 4
-rw----- 1 msfadmin msfadmin 8 2025-10-02 09:49 passwd
msfadmin@metasploitable:~$
```

Impostazione permessi sicuri sul file passwd

```
sudo chmod 600 /home/msfadmin/.vnc/passwd
```

Il comando imposta permessi rw (scrittura/lettura) solo per il proprietario (600) sul file della password VNC ed evita che altri utenti leggano il file della password.

```
msfadmin@metasploitable:~$ sudo chmod 600 /home/msfadmin/.vnc/passwd
[sudo] password for msfadmin:
```

Verifica permessi file passwd

```
ls -l /home/msfadmin/.vnc/passwd
```

Mostra permessi, proprietario e dimensione del file passwd.

```
msfadmin@metasploitable:~$ ls -l /home/msfadmin/.vnc/passwd
-rw----- 1 msfadmin msfadmin 8 2025-10-02 09:49 /home/msfadmin/.vnc/passwd
msfadmin@metasploitable:~$ _
```

Controllo esistenza dello script xstartup (avvio automatico della sessione VNC)

```
ls -l /home/msfadmin/.vnc/xstartup /root/.vnc/xstartup 2>/dev/null
```

Il comando verifica se esistono script xstartup nelle cartelle .vnc (se esiste, potrebbe riavviare il desktop VNC automaticamente)

Output atteso: (vuoto) il file non esiste

```
msfadmin@metasploitable:~$ ls -l /home/msfadmin/.vnc/xstartup /root/.vnc/xstartu
p 2>/dev/null
msfadmin@metasploitable:~$ _
```

Controllo script di init e rc.local per VNC

```
sudo grep -R "vnc" /etc/init.d /etc/rc.local 2>/dev/null || true
```

Il comando cerca ricorsivamente la stringa vnc negli script di init (/etc/init.d) e in /etc/rc.local. Siccome Meta usa SysV init, se VNC viene avviato automaticamente lo troveremo qui.

Output atteso: (vuoto)

```
msfadmin@metasploitable:~$ sudo grep -R "vnc" /etc/init.d /etc/rc.local 2>/dev/n
ull || true
/etc/rc.local:rm -f /root/.vnc/*.pid
/etc/rc.local:HOME=/root LOGNAME=root USER=root nohup /usr/bin/vncserver :0 >/ro
ot/vnc.log 2>&1 &
```

L'output però mostra che **rc.local** avvia automaticamente VNC al boot e crea i file pid. Adesso è necessario commentare queste righe in rc.local così VNC non verrà più avviato automaticamente.

```
sudo sed -i.bak 's/^/#/' /etc/rc.local
```

Il comando modifica /etc/rc.local con permessi di root, creando prima un backup /etc/rc.local.bak. Cerca tutte le righe contenenti "vnc" e aggiunge # all'inizio di ciascuna, trasformandole in commenti. Così VNC non viene più avviato automaticamente al boot, ma il contenuto originale resta salvato nel backup per eventuale ripristino.

```
msfadmin@metasploitable:~$ sudo sed -i.bak 's/^/#/' /etc/rc.local
[sudo] password for msfadmin:
msfadmin@metasploitable:~$
```

Controllo crontab dell'utente msfadmin

```
crontab -l 2>/dev/null || echo "no crontab for msfadmin"
```

Il comando mostra tutti i **job cron** (comandi o script programmati per essere eseguiti automaticamente a intervalli regolari o in momenti specifici sul sistema Linux/Unix.) dell'utente msfadmin.

Se non ci sono job, stampa "no crontab for msfadmin". Serve a verificare se esistono task programmati che potrebbero riavviare automaticamente VNC, così da poterli rimuovere o modificare se presenti

```
msfadmin@metasploitable:~$ crontab -l 2>/dev/null || echo "no crontab for msfadm
in"
no crontab for msfadmin
msfadmin@metasploitable:~$
```

Controllo crontab dell'utente root

```
sudo crontab -l -u root 2>/dev/null || echo "no crontab for root"
```

Il comando mostra tutti i **job cron di root**, se non ci sono job, stampa "no crontab for root". Serve a verificare se root ha task programmati che potrebbero riavviare automaticamente VNC.

```
msfadmin@metasploitable:~$ sudo crontab -l -u root 2>/dev/null || echo "no crontab for root"
[sudo] password for msfadmin:
no crontab for root
msfadmin@metasploitable:~$
```

Controllo autostart utente msfadmin

```
ls -l /home/msfadmin/.config/autostart 2>/dev/null || echo "no autostart dir"
```

Il comando lista i file nella cartella autostart dell'utente msfadmin, dove potrebbero esserci script che avviano programmi all'accesso. Se la cartella non esiste, stampa "no autostart dir". Serve a verificare che VNC non venga eseguito automaticamente all'avvio della sessione grafica.

```
msfadmin@metasploitable:~$ ls -l /home/msfadmin/.config/autostart 2>/dev/null || echo "no autostart dir"
no autostart dir
msfadmin@metasploitable:~$
```

Blocco temporaneo porta VNC

```
sudo iptables -A INPUT -p tcp --dport 5900 -j DROP
```

```
sudo iptables -L -n --line-numbers | egrep '5900|VNC'
```

Il primo comando aggiunge una regola che scarta tutto il **traffico TCP** in ingresso destinato alla porta **5900** (protezione immediata).

Il secondo mostra le regole correnti e filtra quelle relative a **5900** per verificare che la regola sia stata applicata.

```
msfadmin@metasploitable:~$ sudo iptables -A INPUT -p tcp --dport 5900 -j DROP
[sudo] password for msfadmin:
msfadmin@metasploitable:~$ sudo iptables -L -n --line-numbers | egrep '5900|VNC'
1 DROP tcp -- 0.0.0.0/0 0.0.0.0/0 tcp dpt:5900
msfadmin@metasploitable:~$
```

L'output conferma che la regola è stata applicata, tutto il **traffico TCP** verso la porta **5900** viene **droppato** (cioè bloccato).

Verifica Su Kali

```
nmap -p 5900 192.168.50.101
```

Il comando scansiona la porta **5900/TCP** sul target (**192.168.50.101**), la porta dovrebbe risultare **filtered** o **closed**, non più open, a confermare che la regola firewall sta funzionando.

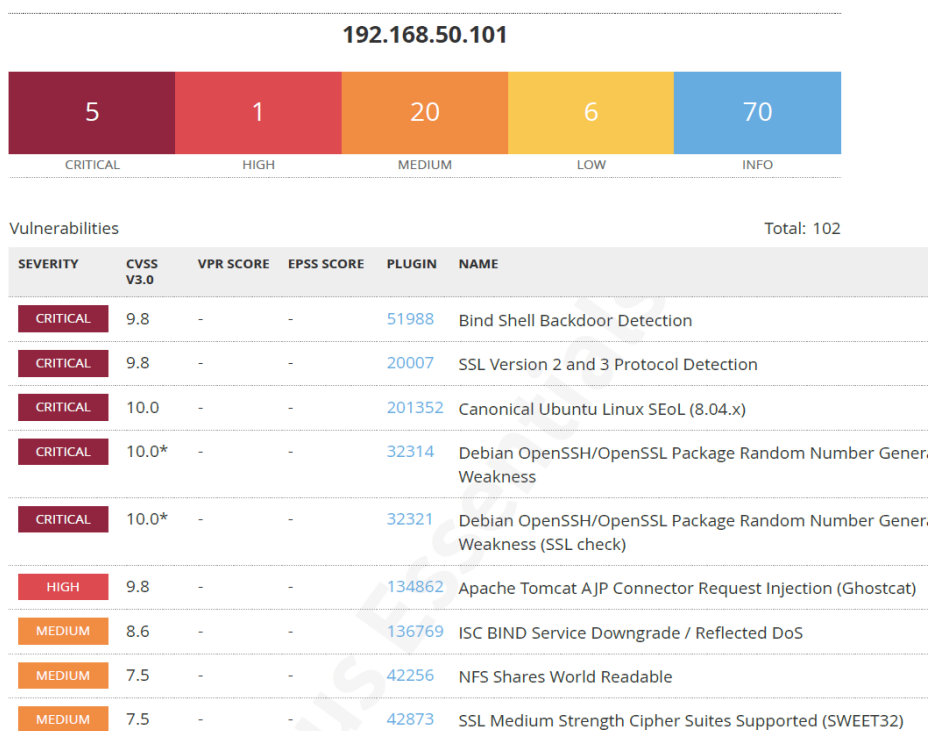
```
(nemi@kali)-[~]
└─$ nmap -p 5900 192.168.50.101
Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-02 20:02 CEST
Nmap scan report for 192.168.50.101
Host is up (0.00043s latency).

PORT      STATE      SERVICE
5900/tcp   filtered   vnc
MAC Address: 08:00:27:09:7A:98 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 13.42 seconds
```

L'output: **5900/tcp filtered vnc** indica che la porta non è più raggiungibile, la regola **iptables** funziona e il servizio VNC non è più accessibile dall'esterno.

Seconda scan di Nessus:



Conclusion

La seconda scansione con Nessus ha confermato l'avvenuta mitigazione: la vulnerabilità legata a VNC non risulta più presente e la porta 5900 è correttamente filtrata, garantendo che il servizio non sia più accessibile da remoto.